

BASE DE DATOS

MODULO 8: Seguridad y Privacidad en Bases de Datos

ALUMNO: Pichulman, Miguel Angel

LEGAJO: 100346

CARRERA: Tecnicatura Universitaria en Programación – Modalidad a distancia

FECHA: 5 de noviembre de 2025

Explorando el Cifrado Homomórfico para la Protección de Datos en Uso

¿Qué es el cifrado homomórfico? (Definición y concepto básico).

El Cifrado Homomórfico es un tipo de algoritmo de cifrado que permite realizar **operaciones matemáticas y cálculos directamente sobre datos cifrados** (texto cifrado), sin la necesidad de descifrarlos previamente. Una vez que se completa la operación, el resultado, que también está cifrado, se puede descifrar para obtener el resultado correcto de la operación, como si se hubiera realizado sobre los datos originales (texto plano)

¿Cuál es su principio fundamental y cómo se diferencia de otras técnicas de cifrado más tradicionales (como el cifrado en reposo o en tránsito) en términos de su aplicación a los datos en uso?

- Principio Fundamental: Permite aplicar un cálculo a un texto cifrado, $E(x)$, para obtener un resultado cifrado, $E(f(x))$, de tal forma que al descifrarlo se obtenga el resultado correcto, $f(x)$. Esto significa que un tercero puede realizar análisis sin acceder a los datos reales.

- Diferencia con el Cifrado Tradicional: Se distingue de técnicas tradicionales (como el cifrado en reposo o en tránsito) en términos de su aplicación a los datos en uso, ya que el CH mantiene los datos protegidos durante el procesamiento, mientras que las técnicas tradicionales requieren que los datos sean descifrados en la memoria para poder ser procesados.

Identifique al menos dos ventajas clave y dos desafíos o limitaciones para su implementación en sistemas de bases de datos a gran escala.

El Cifrado Homomórfico es especialmente relevante para el procesamiento seguro en entornos de nube o de terceros.

Ventajas Clave

1. Privacidad y Confidencialidad Reforzadas: Permite externalizar el análisis de datos sensibles (financieros, de salud) a proveedores externos sin comprometer la confidencialidad, ya que el proveedor opera solo con datos cifrados.
2. Cumplimiento Normativo Facilitado: Ayuda a cumplir normativas de privacidad (como la Ley 25.326 en Argentina o el RGPD en la UE) al garantizar que la información se mantenga protegida, incluso durante el cómputo.

Desafíos o Limitaciones

1. Rendimiento y Complejidad Computacional: El CH es significativamente más lento y requiere un alto consumo de recursos computacionales (tiempo de procesamiento, memoria), lo que supone un desafío para sistemas de bases de datos a gran escala y en tiempo real.

2. Implementación de Consultas: La complejidad en la implementación obliga a reingenierías complejas de las consultas de bases de datos, ya que estas deben mapearse a las operaciones aritméticas que el algoritmo de CH pueda soportar (suma, multiplicación).

Mencione al menos dos ejemplos concretos de aplicaciones potenciales donde el cifrado homomórfico podría ser particularmente útil para garantizar la privacidad y seguridad de los datos en bases de datos.

- Análisis Predictivo en el Sector Sanitario: Permite realizar análisis e investigaciones sobre datos genómicos o historiales clínicos cifrados para obtener tendencias y patrones, sin exponer la información personal de los pacientes.

- Servicios de Búsqueda Segura: Un motor de búsqueda puede realizar consultas sobre un índice de datos cifrados sin que el proveedor del servicio de búsqueda (o la nube) sepa qué términos se están buscando ni cuáles son los resultados, garantizando la privacidad del usuario y de la información.

Técnicas de Auditoría y Monitoreo en Bases de Datos Relacionales

¿Cuál es el propósito principal de la auditoría y el monitoreo en la seguridad de bases de datos?

El propósito principal es doble:

-Detección de Incidentes: La auditoría y el monitoreo ayudan a detectar actividades sospechosas en tiempo real o casi real.

-Registro Forense y Mantenimiento de la Integridad: La auditoría de la base de datos ayuda a identificar cambios no autorizados en registros críticos y proporciona un registro inmutable que es vital para el análisis forense post-incidente.

Describa al menos tres tipos de actividades o eventos específicos que deben ser monitoreados en una base de datos para detectar posibles incidentes de seguridad.

Para detectar posibles incidentes de seguridad, se deben monitorear eventos específicos:

1. Seguimiento de Inicios de Sesión y Autenticación: Se monitorean los intentos de inicio de sesión exitosos, fallidos, los cambios de credenciales y los intentos de acceso fuera del horario habitual o desde ubicaciones sospechosas.
2. Cambios de Esquema (DDL): Incluye la supervisión de la creación, modificación o eliminación de tablas, índices, procedimientos almacenados y, en especial, cambios en permisos y privilegios de usuario, lo que podría indicar una escalada de privilegios.
3. Ejecución de Consultas Anormales (DML): Se monitorean las consultas de gran volumen (SELECT) a tablas sensibles (exfiltración de datos), así como operaciones de modificación (INSERT, UPDATE, DELETE) en registros críticos.

Explique cómo las herramientas de Gestión de Eventos e Información de Seguridad (SIEM) pueden mejorar la detección de incidentes al analizar registros de auditoría de bases de datos.

Las herramientas de Gestión de Eventos e Información de Seguridad (SIEM) mejoran la detección de incidentes al analizar registros de auditoría de bases de datos de la siguiente manera:

- Correlación de Eventos: SIEM recopila y centraliza los registros de auditoría de la base de datos y los correlaciona con eventos de otros dispositivos (firewalls, servidores, aplicaciones). Esto permite identificar patrones de ataque complejos que se extienden a través de múltiples capas del sistema (por ejemplo, un inicio de sesión exitoso seguido de una transferencia masiva de datos).
- Análisis y Alerta en Tiempo Real: Utiliza reglas y analíticas avanzadas para analizar los logs a gran velocidad, generando alertas inmediatas ante actividades que violan las políticas de seguridad o que representan un comportamiento anómalo.

Argumente la importancia de la auditoría y el monitoreo para el cumplimiento legal y normativo.

La auditoría y el monitoreo son cruciales para el cumplimiento legal y normativo:

- Requisito de Seguridad: Normativas como la Ley 25.326 en Argentina y el RGPD en la UE exigen explícitamente que las organizaciones implementen medidas de seguridad de datos para proteger la información personal del cliente.
- Demostración de Diligencia: La auditoría proporciona la prueba necesaria de que la organización está monitoreando activamente sus sistemas, aplicando políticas de acceso y detectando posibles amenazas. Esto es vital para mitigar sanciones al demostrar el esfuerzo por proteger la información personal del cliente y cumplir con las regulaciones.

Estrategias de Respaldo y Recuperación para la Resiliencia de Bases de Datos

Defina la importancia fundamental de las estrategias de respaldo y recuperación en el contexto de la seguridad y disponibilidad de las bases de datos.

Su importancia radica en garantizar la resiliencia y disponibilidad de los datos:

- Continuidad Operativa: Permiten a la organización restaurar el sistema y reanudar las operaciones rápidamente tras un desastre, interrupción operativa, o ataque malicioso (como *ransomware*).
- Mitigación de Pérdida de Datos: Aseguran que los datos críticos no se pierdan permanentemente debido a fallas de *hardware* o errores humanos, garantizando la consistencia y la integridad de la información.

Describe detalladamente los siguientes tipos de respaldo, explicando cuándo se aplica cada uno y sus implicaciones para la recuperación:

Tipo de Respaldo	Descripción Detallada	Implicaciones para la Recuperación
Respaldo Completo	Copia completa de toda la base de datos.	Es el punto de partida para cualquier restauración. Es el más rápido de restaurar, ya que solo requiere un archivo, pero es el que más tiempo tarda en crearse y más espacio ocupa.
Respaldo Diferencial	Guarda solo los cambios que se han producido desde el último respaldo completo.	La restauración requiere solo dos archivos: el último respaldo completo y el último respaldo diferencial. Es más rápido de restaurar que el incremental.
Respaldo Incremental	Registra los cambios desde el último respaldo de cualquier tipo (completo, diferencial o incremental).	La restauración es la más lenta, ya que requiere el último respaldo completo más todos los respaldos incrementales subsiguientes en orden cronológico.
Respaldo de Registro de Transacciones (Log)	Registro de todas las transacciones realizadas en la base de datos.	Es crucial para la recuperación puntual (<i>Point-in-Time Recovery</i>), permitiendo restaurar la base de datos hasta un instante específico, minimizando la pérdida de datos.

Explique la "Regla 3-2-1" para respaldos y justifique por qué cada uno de sus componentes es vital para una estrategia de protección de datos robusta.

La "Regla 3-2-1" es fundamental para una estrategia de protección de datos robusta, ya que elimina un punto único de fallo.

- Tres (3) copias de los datos: Se deben mantener al menos tres copias de los datos (la copia original y dos respaldos).
 - Vitalidad: Asegura que si una copia falla o se corrompe, todavía existen al menos dos alternativas para la restauración.
- Dos (2) tipos de almacenamiento diferentes: Las copias deben almacenarse en dos tipos de almacenamiento distintos (ej. disco local y cinta, o NAS y nube).
 - Vitalidad: Reduce el riesgo de que un fallo de hardware específico o un problema de plataforma comprometa todas las copias a la vez.
- Una (1) copia almacenada fuera del sitio o en la nube: Se debe tener una copia en una ubicación física separada de la ubicación principal.
 - Vitalidad: Protege contra desastres locales (incendios, inundaciones o fallas de energía) y ataques cibernéticos que se propagan dentro de la red principal.

TECNICATURA UNIVERSITARIA EN PROGRAMACIÓN A DISTANCIA



Discuta la relación entre las estrategias de respaldo y la definición del Objetivo de Punto de Recuperación (RPO) y el Objetivo de Tiempo de Recuperación (RTO), así como la importancia de probar y documentar los procedimientos de recuperación.

- Objetivo de Punto de Recuperación (RPO): Se relaciona con la máxima cantidad de datos que una organización puede permitirse perder. La frecuencia y el tipo de respaldo (especialmente el uso del registro de transacciones) determinan el RPO. Un RPO bajo exige copias de seguridad muy frecuentes.
- Objetivo de Tiempo de Recuperación (RTO): Se relaciona con el tiempo máximo aceptable para restaurar las operaciones del negocio. La estrategia de recuperación elegida (por ejemplo, restauración desde un completo versus incremental) y la infraestructura disponible impactan directamente en el RTO.

La prueba y documentación de los procedimientos de recuperación son vitales. Las pruebas periódicas aseguran que los respaldos sean utilizables y que los procedimientos funcionen dentro de los tiempos RPO y RTO definidos. La documentación garantiza que cualquier persona del equipo pueda ejecutar la recuperación de forma correcta y consistente durante una emergencia.

Referencias

IBM. (2021, 8 de abril). *Fully Homomorphic Encryption is More Real Than You Think*. IBM Research Blog. Recuperado de <https://www.ibm.com/blogs/research/2021/04/08/fully-homomorphic-encryption-is-more-real-than-you-think/>

Ley 25.326. (2000). *Protección de los Datos Personales*. Boletín Oficial de la República Argentina.

Microsoft. (s.f.). *SQL Server Audit (Database Engine)*. Microsoft Learn. Recuperado de <https://learn.microsoft.com/es-es/sql/relational-databases/security/auditing/sql-server-audit-database-engine?view=sql-server-ver16>

Microsoft Research. (s.f.). *Homomorphic Encryption*. Recuperado de <https://www.microsoft.com/en-us/research/project/homomorphic-encryption/>

OpenFHE. (2024). *OpenFHE: Open-Source Fully Homomorphic Encryption Library*. Recuperado de <https://www.openfhe.org/>

Oracle. (s.f.). *Oracle Database Documentation*. Recuperado de <https://docs.oracle.com/en/database/oracle/oracle-database/index.html>

Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo (RGPD). (2016). *Diario Oficial de la Unión Europea*.